

L2-07

O artigo apresenta um mapeamento sistematizado da literatura (SMS) sobre desenvolvimento seguro de software. O objetivo é entender como a comunidade científica trata o tema, quais práticas e ferramentas são propostas e em que fase do ciclo de vida (SDLC) elas se concentram.

A metodologia segue os passos clássicos do SMS:

1. Definir questões de ~~pesquisa~~ pesquisa.
2. Buscar em bases científicas (IEEE, ACM, Scopus, Springer).
3. Selecionar por critérios de inclusão e exclusão.
4. Extrair os dados e categorizar.
5. Sintetizar em mapas e gráficos.

Principais achados:

- A maioria dos estudos foca em codificação e testes, com menor atenção a requisitos e arquitetura/design.
- Há concentração em vulnerabilidades Web (OWASP Top 10), ~~software~~ injection e XSS.
- Práticas mais citadas: modelagem de ameaças, revisão de código, análise estática (SAST) e Dinâmica (DAST), Testes de penetração.
- Frameworks recentes: Microsoft SDL, OWASP SAMM, BIS e NIST SSDF.

Oportunidades identificadas: integração de segurança em metodologias ágeis e DevOps (DevSecOps), automação em pipelines de CI/CD e educação dos desenvolvedores.

Conclusão: apesar do aumento crescente de pesquisas, ainda há desconexão entre Teoria e prática - as empresas adotam soluções pontuais em vez de tratar segurança como atributo transversal. O artigo recomenda mais estudos empíricos, ferramentas integradas ao fluxo de desenvolvedor e treinamentos contínuos.